CONFIDENTIAL **MOCK EXAM 2026**

GENERIC UNIVERSITY FINAL EXAMINATION

INSTRUCTIONS TO CANDIDATES

1. This question paper consists of two (2) parts: PART A (10 Questions)
   PART B (2 Questions)

2. Answer ALL questions in the Answer Booklet. Start each answer on a new page.

3. Do not bring any material into the examination room unless permission is given by the invigilator.

4. Please check to make sure that this examination pack consists of:

   i) the Question Paper
   ii) an Answer Booklet - provided by the Faculty

5. Answer ALL questions in English.

DO NOT TURN THIS PAGE UNTIL YOU ARE TOLD TO DO SO

This examination paper consists of 5 printed pages

PART A (80 MARKS)

QUESTION 1

a) State TWO (2) differences between morals and laws as described in the lecture on ethics and computer security.

(2 marks)

b) Describe six (6) professional conduct requirements that the ACM code of ethics places on a computing professional, as presented in the lecture on ethics and computer security.

(6 marks)

QUESTION 2

a) A company is deploying a network-based intrusion detection system (NIDS) across its campus network. List TWO (2) typical locations where NIDS sensors should be placed.

(2 marks)

b) Explain three preventive network security mechanisms that an organization can deploy to protect its network, and for each mechanism describe how it controls or secures network traffic.

(6 marks)

QUESTION 3

a) Explain the Chinese Wall model as a formal security model, stating the specific concern it was designed to address and how its access decisions differ from static policies.

(2 marks)

b) Describe six points about the access control matrix, access control lists and capabilities as access control structures, covering what each structure represents and the stated advantages or disadvantages of these structures.

(6 marks)

QUESTION 4

a) List TWO (2) facts about the chain of trust in Trusted Computing, including how measurements are stored and where the chain begins.

(2 marks)

b) Explain the roles of the two primary system components of the Next Generation Secure Computing Base (NGSCB), and describe how the Nexus interacts with trusted software and the TPM.

(6 marks)

QUESTION 5

a) State TWO (2) ways in which a documented code of ethics guides the ethical conduct of computing professionals, as described in the lecture on ethics and computer security.

(2 marks)

b) Compare the responsibilities that the ACM code of ethics places on a computing professional with respect to privacy and confidentiality, and explain how a documented code of ethics supports an organisation in enforcing acceptable professional behaviour.

(6 marks)

QUESTION 6

a) Explain the two stages of the biometric authentication process and state what happens during each stage.

(2 marks)

b) Refer to your answer in (a). A bank plans to replace password logins at its branch counters with biometric authentication. Explain six points the bank must consider regarding biometric mechanisms and technologies, covering the definition of a biometric, its categories, and specific technologies with their limitations.

(6 marks)

QUESTION 7

a) State TWO (2) characteristics of a Trojan horse as a type of malware.

(2 marks)

b) Explain six (6) techniques by which malware propagates itself or infects host programs and systems, as described in the lecture material.

(6 marks)

QUESTION 8

a) Explain how the classes of threats described in the lecture can impact the confidentiality, integrity and availability of a system's assets.

(2 marks)

b) Discuss the Samy worm as a case study of a cross-site scripting (XSS) attack, covering how the malicious script was injected, how it spread to other users, and the outcome of the incident.

(6 marks)

QUESTION 9

a) Explain the goals of access control and the role of a reference monitor in realizing access control policies.

(2 marks)

b) Discuss the formal security models covered in the lecture, focusing on the Bell-La Padula, Biba and Chinese Wall models. In your answer, explain the concern each model addresses and the specific access rules that the Chinese Wall model imposes on subjects.

(6 marks)

QUESTION 10

a) Explain two ways in which an intrusion detection system supports the detection and defence of a system against attacks.

(2 marks)

b) State six (6) points from the lecture that characterise threat classes and the countermeasures used against them, covering how threats, attacks and vulnerabilities are distinguished, how malware is described, and how protective mechanisms are classified.

(6 marks)

PART B (20 MARKS)

QUESTION 1

A small company runs a shared Linux server for its staff. The administrator notices that several users still rely on weak passwords and that failed login attempts are never acted upon. She decides to strengthen the password security controls on the server.

a) Explain five password security controls the administrator can apply to strengthen authentication on the shared Linux server.

(5 marks)

b) The administrator in the scenario wants to reduce the number of passwords staff must remember and type on the shared Linux server. Explain five points about single sign-on and Kerberos that she should understand before adopting such a mechanism.

(5 marks)

QUESTION 2

a) Discuss software insecurity and buffer overflows in the context of the consultant's review. Your answer should address the root causes of software insecurity, how a stack buffer overflow occurs, and the mitigation techniques available.

(5 marks)

b) State five Windows security mechanisms or features that the consultant would examine, and for each, note the security concern it raises.

(5 marks)

END OF QUESTION PAPER